

- **Expediente N.º: EXP202300329**

RESOLUCIÓN DE TERMINACIÓN DEL PROCEDIMIENTO POR PAGO
VOLUNTARIO

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: **A.A.A.** (en adelante, **A.A.A.**) con fecha 15 de noviembre de 2022 interpuso reclamación ante la Agencia Española de Protección de Datos. La reclamación se dirige contra **BANCO BILBAO VIZCAYA ARGENTARIA, S.A.** con NIF **A48265169** (en adelante, BBVA). Los motivos en que basa la reclamación son los siguientes:

A.A.A. manifiesta que un empleado de BBVA, el 30 de octubre de 2022, facilitó, a través de un mensaje de correo electrónico, a varias personas, información bancaria relativa a su persona, sin su consentimiento. Añade que dicho empleado no estaba autorizado a acceder a dicha información, ya que **A.A.A.** presentó un poder notarial indicando que solo sus tres apoderados podían tener acceso a su cuenta. Añade que dicho empleado extrajo la citada información de la entidad bancaria, en soporte físico y, posteriormente escaneó los documentos relativos a su persona para proceder a su envío a terceros.

Junto a la reclamación se aporta:

- Copia de un correo electrónico de 30 de octubre de 2022 a las 8:31hs, remitido por *****EMAIL.1** a *****EMAIL.2**, con copia a *****EMAIL.3; ***EMAIL.4; ***EMAIL.5; ***EMAIL.6; ***EMAIL.7; ***EMAIL.8; ***EMAIL.9**. Este correo electrónico tenía como asunto "Re: (...)".

- Fotografía de una documentación bancaria, relativa a un extracto de movimientos bancarios de fecha 3 de marzo de 2020 de una cuenta bancaria de **A.A.A.** (Código Cuenta Cliente IBAN **ES00 0000 0000 0000 0000 0000**). En su encabezado, dirigido a la reclamante y a su dirección postal, puede leerse: *"Distinguido cliente, nos es grato solicitarle detalle de los movimientos que nos tiene solicitado"*.

- Dos fotografías parciales de otros documentos en un formato distinto, relativos a conceptos varios como **"(...)"**, figurando fecha, importe y unos códigos **"(...)"** seguidos de varios números, constando, además, en el extremo derecho del documento en relación con diferentes conceptos, lo siguiente: **"(...)"**.

SEGUNDO: **B.B.B.** (en adelante, **B.B.B.**) con fecha 17 de noviembre de 2022 interpuso reclamación ante la Agencia Española de Protección de Datos. La reclamación se dirige contra **BANCO BILBAO VIZCAYA ARGENTARIA, S.A.** con NIF

A48265169 (en adelante, BBVA). Los motivos en que basa la reclamación son los siguientes:

B.B.B. manifiesta que un "empleado o ex empleado" de BBVA, en fecha 30 de octubre de 2022, facilitó, a través de un mensaje de correo electrónico, a ocho personas, información bancaria relativa a **B.B.B.**, sin su consentimiento. Añade que dicho empleado no estaba autorizado a acceder a dicha información y que extrajo la misma de la entidad bancaria, en soporte físico y, posteriormente escaneó los documentos relativos a su persona para proceder a su envío a terceros.

Junto a la reclamación aporta:

- Copia de un correo electrónico de 30 de octubre de 2022 a las 8:31hs, remitido por *****EMAIL.1** a *****EMAIL.2**, con copia a *****EMAIL.3; ***EMAIL.4; ***EMAIL.5; ***EMAIL.6; ***EMAIL.7; ***EMAIL.8; ***EMAIL.9**". Este correo electrónico tenía como asunto "Re: (...)".

- Asimismo, se aporta copia de diez fotografías que contienen documentación bancaria grapada, consistente en un cuadro de amortización de un préstamo, cuyo titular es **B.B.B.**, figurando en algunos documentos anotaciones manuscritas indicando "Pagado por mí" y "Las deudas pendientes fueron pagadas por **C.C.C.** (...)".

TERCERO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGDD), se dio traslado de la reclamación presentada por **A.A.A.** a BBVA, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

El traslado, que se practicó conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), fue recogido en fecha 16/01/2023 como consta en el acuse de recibo que obra en el expediente.

Con fecha 17 de marzo de 2023 tuvo entrada escrito de BBVA de respuesta al traslado de la reclamación de **A.A.A.** en el que pone de manifiesto, entre otros, lo siguiente:

- El 16/03/2023 el Servicio de Atención al Cliente de BBVA comunicó por escrito a **A.A.A.** la decisión acordada con respecto a la reclamación presentada ante esta Agencia, mediante correo electrónico enviado a (...). Se aporta como Documento nº 1 un escrito dirigido a **A.A.A.** con, entre otro, el siguiente contenido:

"(...) Así mismo, le informamos que el correo electrónico que nos ha facilitado y conforme al cual manifiesta que BBVA es responsable de la cesión inconsentida de sus datos personales, no corresponde a ningún dominio del Grupo BBVA. Dado que el remitente es una dirección personal, no vinculada al Grupo BBVA, la Entidad no puede determinar la identidad del remitente y la autenticidad del correo electrónico.

Atendiendo a que el extracto bancario que supuestamente se adjunta en el correo es de fecha 03/03/2020, y que dicho correo electrónico se envía el 30/10/2022, no se

evidencia un nexo causal entre el acceso y el posterior envío del correo, teniendo en cuenta como se ha indicado previamente que este se realiza desde una dirección de correo electrónico ajena al Grupo BBVA. (...)”

- Como resultado del análisis se ha detectado que el 3 de marzo de 2020 (fecha del extracto de la cuenta) se realiza desde la oficina (...) situada en *****DIRECCIÓN.1**, que no se corresponde con la oficina gestora de la cuenta, una consulta de movimientos de la cuenta **IBAN ES0000000000000000000000**. El usuario que figura en el registro de la transacción, y que por tanto accedió a la consulta de saldo y movimientos de la cuenta, está desvinculado de la Entidad BBVA con motivo de su adscripción al ERE (Expediente de Regulación de Empleo) con fecha de efecto 01/08/2021. La extinción de la relación laboral ha impedido a la Entidad conocer la versión del trabajador sobre los hechos.

- El correo electrónico que se aporta con la reclamación de **A.A.A.** y del que se sirve para acreditar la cesión no consentida de sus datos personales, es el reenvío de un correo a otro usuario (...), y en este proceso el contenido del correo electrónico puede no coincidir con el texto original por diferentes motivos.

- El correo electrónico que según **A.A.A.** lleva adjunto el extracto de su cuenta bancaria de fecha 03/03/2020, se remite desde la dirección (...) que no pertenece al dominio del Grupo BBVA (@bbva.com). Como la dirección de e-mail remitente es una dirección personal no vinculada a BBVA, éste no puede determinar la identidad del remitente y la autenticidad del correo electrónico.

Atendiendo a la fecha del extracto bancario 03/03/2020 y a la fecha del envío del correo electrónico 30/10/2022, no hay a juicio de BBVA un nexo causal aparente entre dicho acceso y el envío del correo en el que supuestamente se adjunta el extracto bancario, ya que tiene lugar más de dos años después, y la dirección remitente es ajena al Grupo BBVA.

- Se aporta copia de la siguiente documentación, relativa a la seguridad y confidencialidad de los datos de carácter personal:

- Como Documento nº2: “Protocolo de Protección de Datos y Experiencia Cliente” realizado en colaboración con el Departamento de Data Protección Office (DPO) y que contiene recomendaciones sobre cómo tratar los datos personales de clientes con la seguridad y confidencialidad. El protocolo se encuentra en la intranet de interna de la Entidad por lo que es accesible a los empleados.

En este documento se observa, entre otro, el siguiente contenido:

- “(...)”.
- “(...)”.
- “(...)”
- Como Documento nº3: Información a los empleados mediante un boletín de noticias denominado “Hoy” facilitada el lunes 12 de marzo de 2018, que incluye

un enlace al protocolo referido en el apartado anterior. En este documento se observa, entre otro, el siguiente contenido:

“(...).”

- Como Documento nº4: “Código de Conducta del Grupo BBVA” que recoge la obligación de los empleados de guardar y mantener la confidencialidad de los datos que traten. Además, se obligarán a no difundir, transmitir o revelar a terceros cualquier información relacionada o datos a que tengan acceso como consecuencia del desempeño de su actividad, ni a utilizar tal información en interés propio. Esta obligación subsistirá aún finalizada la relación contractual. En este documento se observa, entre otro, el siguiente contenido:

- “(…).”
- “(…).”
- “(…).”
- “(…).”
- “(…).”

Los empleados que se adscribieron al ERE formalizaron con la Entidad una “Carta de Despido” en la que se incluía la obligación de confidencialidad y de guardar el secreto profesional cuya copia adjuntan.

También se señala que: *“La citada norma interna de “Protección de Datos de Carácter Personal”, resulta de aplicación a cualquier tratamiento de datos de carácter personal que se lleve a cabo, con independencia del colectivo al que pertenezcan los datos: clientes, no clientes, empleados, accionistas, apoderados, etc., es de aplicación a todas las unidades que conforman la geografía de España sujetas al cumplimiento de los requisitos regulatorios del país, está a disposición de los empleados, y su contenido se recuerda de forma habitual mediante campañas de información.*

En la referida norma se advierte de la siguiente previsión que tiene relación con el objeto de esta reclamación: (...).”

CUARTO: De conformidad con el artículo 65.4 de la LOPDGDD, se dio traslado de la reclamación presentada por **B.B.B.** a BBVA, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

El traslado, que se practicó conforme a las normas establecidas en la LPACAP, fue recogido en fecha 16/01/2023 como consta en el acuse de recibo que obra en el expediente.

Con fecha 17 de marzo de 2023 tuvo entrada escrito de BBVA de respuesta al traslado de la reclamación presentada por **B.B.B.** en el que pone de manifiesto, entre otros, lo siguiente:

- El correo electrónico que se aporta con la reclamación de **B.B.B.** y del que se sirve para acreditar la cesión no consentida de sus datos personales, es el reenvío de un correo a otro usuario (...), y en este proceso el contenido del correo electrónico puede no coincidir con el texto original por diferentes motivos.

- El correo electrónico que según **B.B.B.** lleva como documentos adjuntos las fotografías que se aportan, se remite desde la dirección (...) que no pertenece al dominio del Grupo BBVA (@bbva.com). Resultando que la dirección de e-mail remitente es una dirección personal no vinculada a BBVA, no siendo posible determinar la identidad del remitente y la autenticidad del correo electrónico.

- En cuanto a las fotografías aportadas: (i) las tres primeras imágenes parece que se trata de la validación mecánica de ingresos en cuenta, de ser así la persona que realiza el ingreso recibe copia del resguardo del ingreso; (ii) la tercera imagen es ilegible, parece una captura de pantalla del aplicativo de BBVA; (iv) las imágenes quinta, sexta y séptima parece que se corresponden con un cuadro de amortización de un préstamo (cuotas desde el 2003 hasta el 2013); no existe un nexo causal entre estas imágenes y la alegada por el reclamante cesión de datos no consentida por parte de BBVA. Las imágenes que acompañan según manifiesta **B.B.B.** se acompañan en un correo electrónico cuyo remitente no es posible identificar, al tratarse de una dirección personal y no tener relación el dominio con BBVA. No se evidencia que el acceso a la documentación aparentemente del año 2008 y 2013, se haya facilitado por BBVA a un tercero distinto del titular. Cualquier documento que se corresponda, por ejemplo, como en este caso, con un cuadro de amortización de un préstamo, en manos de un tercero diferente del titular, no implica que se trate de una vulneración a la protección de datos del cliente por parte de la Entidad, ya que el acceso al documento una vez que se entrega al cliente en la formalización de la operación se escapa del control del Banco.

- Se aporta copia de la siguiente documentación, relativa a la seguridad y confidencialidad de los datos de carácter personal:

- Como Documento nº2: “Protocolo de Protección de Datos y Experiencia Cliente”, que es el mismo documento presentado por BBVA en su escrito de 17 de marzo de 2023 de respuesta de al traslado de la reclamación de **A.A.A.**, reseñado en el hecho tercero.
- Como Documento nº3: Información a los empleados mediante un boletín de noticias denominado “Hoy” facilitada el lunes 12 de marzo de 2018, que es el mismo documento presentado por BBVA en su escrito de 17 de marzo de 2023 de respuesta de al traslado de la reclamación de **A.A.A.**, reseñado en el hecho tercero.
- Como Documento nº4: “Código de Conducta del Grupo BBVA”, que es el mismo documento presentado por BBVA en su escrito de 17 de marzo de 2023 de respuesta de al traslado de la reclamación de **A.A.A.**, reseñado en el hecho tercero.

- La citada norma interna de “Protección de Datos de Carácter Personal”, resulta de aplicación a cualquier tratamiento de datos de carácter personal que se lleve a cabo, con independencia del colectivo al que pertenezcan los datos: clientes, no clientes, empleados, accionistas, apoderados, etc., es de aplicación a todas las unidades que conforman la geografía de España sujetas al cumplimiento de los requisitos regulatorios del país, está a disposición de los empleados, y su contenido se recuerda de forma habitual mediante campañas de información.

Manifiestan que en la referida norma se recoge la siguiente advertencia y que tiene relación con el objeto de esta reclamación: “(…).”

QUINTO: Con fecha 15 de febrero de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación presentada por **A.A.A.**

SEXTO: Con fecha 17 de febrero de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación presentada por **B.B.B.**

SÉPTIMO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VII, Capítulo I, Sección segunda, de la LOPDGDD, teniendo conocimiento de los siguientes extremos:

El 21 de junio y 21 de agosto de 2023 tuvieron entrada en esta Agencia dos escritos, en respuesta a requerimientos sobre información respecto a la reclamación presentada por **B.B.B.**, en el que BBVA pone de manifiesto lo siguiente:

1. Los datos **del B.B.B.** figuran bloqueados LOPD como consecuencia de la cancelación de todos los productos en BBVA en el mes de diciembre de 2020 y no tiene contratos activos desde esa fecha.

Se adjunta imagen de una búsqueda por “NIF PERSONA FISICA” con Documento “*****NIF.1**” en la que puede verse “No existen datos para la consulta”.

2. Las tres primeras imágenes se corresponden con justificantes de ingresos de efectivo en cuenta, la fecha de los justificantes parece ser del año 2002 o 2003. Para realizar un ingreso en cuenta por parte de quien no figura como interviniente de la misma se requiere del número de cuenta donde se solicita el ingreso. El plazo general de conservación de los documentos es de diez años desde la terminación de la relación de negocio o la ejecución de la operación ocasionada (artículo 29.1 del reglamento de la Ley 10/2010 de Prevención del Blanqueo de Capitales).

3. Respecto del cuadro de amortización de un préstamo, es parte integrante del contrato o póliza formalizada entre el titular y la Entidad. Según la captura de la aplicación informática los préstamos fueron cancelados en 2005, 2009 y 2013.

4. No existen accesos en el año 2022. Desde el 03/2020 hasta el 03/12/2020 existen 137 registros, del análisis de los accesos no ha resultado que ninguna actividad sospechosa o que carezca de motivación distinta a acciones comerciales habituales.

Con fecha 22 de agosto de 2023 tuvo entrada en esta Agencia un escrito, en respuesta a un requerimiento sobre información respecto a la reclamación presentada por A.A.A. en el que BBVA pone de manifiesto lo siguiente:

1. Los clientes deben identificarse con su DNI y/o documento de identificación original y en vigor, aunque la oficina tenga escaneado el documento facilitado en la apertura de la cuenta, y con independencia del importe a disponer. Aportan copia de Norma interna “Norma para la admisión, identificación y conocimiento de los clientes”.

2. El usuario que realizó el 03/03/2020 (fecha del extracto de la cuenta) desde la oficina (...), una consulta de movimientos de la cuenta IBAN **ES0000000000000000000000**, según consta en los registros de BBVA, corresponde al Sr. **C.C.C.** (en adelante, **C.C.C.**), empleado de la entidad desde el 16/03/1992 al 01/08/2021, fecha de efecto de la baja voluntaria incentivada con motivo de su adscripción al ERE (Expediente de Regulación de Empleo).

3. Añaden que BBVA tiene a disposición de sus empleados en la intranet interna el Código de Conducta del Grupo BBVA, la normativa interna sobre protección de datos (DGPR), y el procedimiento de verificación y acreditación de la identidad de los clientes en ventanilla, y envía mediante correo electrónico de forma periódica boletines informativos con la información más relevante contenida en los referidos documentos. El Código de Conducta del Grupo BBVA es parte de una de las formaciones obligatorias que realizan los empleados de la entidad.

4. En relación con la formación recibida por **C.C.C.** se acompaña como Documento nº 3 certificado que incluye la formación registrada desde el año 2018, y donde entre otros cursos figuran:

(...)

OCTAVO: Según consta en el “Informe Anual 2022”, publicado en https://accionistaseinversores.bbva.com/wp-content/uploads/2023/03/Informe-Anual-BBVA_2022_esp.pdf, en el año 2022 el beneficio de BBVA ha ascendido a 6.420 millones de euros, y contaba con más de 89 millones de clientes, según consta en la diligencia que se incorpora al expediente de fecha 9 de febrero de 2024.

NOVENO: Con fecha 15 de febrero de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a BBVA, a fin de imponerle una multa administrativa de 70.000,00 euros por la supuesta infracción del artículo 32 del RGPD, tipificada en el artículo 83.4 de dicha norma, en el que se le indicaba que tenía un plazo de diez días para presentar alegaciones.

Este acuerdo de inicio, que se notificó a BBVA conforme a las normas establecidas en la LPACAP, fue recogido en fecha 16 de febrero 2024, como consta en el acuse de recibo que obra en el expediente.

Con fecha 8 de marzo de 2024 se recibe en esta Agencia, en tiempo y forma, escrito de BBVA en el que aduce alegaciones al acuerdo de inicio.

DÉCIMO: En fecha 8 de agosto de 2024, BBVA ha procedido al pago de la sanción en la cuantía de **56.000,00 euros** haciendo uso de una de las dos reducciones previstas en el Acuerdo de inicio citado anteriormente y ha presentado un escrito con el siguiente contenido:

“(…)

X. Que, como consecuencia del mencionado pago, mi representada renuncia al ejercicio ante esa AEPD de cualquier acción o recurso en vía administrativa contra la sanción, tal y como prescribe el artículo 85.3 de la LPACAP, por lo que manifiesta que no interpondrá contra la resolución que finalmente se dictase, recurso potestativo de reposición ante esa AEPD.

XI. Que, no obstante, y como se ha indicado en los expositivos anteriores, el mencionado pago se realiza en uso de la facultad establecida en el artículo 85.3 y no supone en ningún caso conformidad con el contenido del Acuerdo de Inicio ni con el de la resolución que en su caso se dictase, si se correspondiese, en todo o en parte, con el contenido de dicho Acuerdo. Del mismo modo, la realización del citado pago en ningún caso debe ser interpretado como un reconocimiento por parte de BBVA de la responsabilidad por la comisión de las supuestas sanciones que pudieran serle impuestas en la citada resolución. (...)”

DÉCIMO PRIMERO: El pago realizado conlleva la renuncia a cualquier acción o recurso en vía administrativa contra la sanción, en relación con los hechos a los que se refiere el Acuerdo de Inicio.

A la vista de todo lo actuado, por parte de la Agencia Española de Protección de Datos en el presente procedimiento se consideran hechos probados los siguientes,

HECHOS PROBADOS

PRIMERO: El 30 de octubre de 2022 **C.C.C.**envió un correo electrónico a “*****EMAIL.2**, con copia a “*****EMAIL.3; ***EMAIL.4; ***EMAIL.5; ***EMAIL.6; ***EMAIL.7; ***EMAIL.8; ***EMAIL.9**”.

Este correo electrónico tenía como asunto “Re: (...)” y a él se acompañaba imagen de una documentación bancaria, relativa a un extracto de movimientos bancarios de fecha 3 de marzo de 2020 de una cuenta bancaria de **A.A.A.** (Código Cuenta Cliente IBAN **ES00 0000 0000 0000 0000**). En su encabezado, dirigido a **A.A.A.** y a su dirección postal, puede leerse: “*Distinguido cliente, nos es grato solicitarle detalle de los movimientos que nos tiene solicitado*”.

Al correo también se acompañaban dos imágenes parciales de otros documentos en un formato distinto, relativos a conceptos varios como "(...)", figurando fecha, importe y unos códigos "(...)" seguidos de varios números, constando, además, en el extremo derecho del documento en relación con diferentes conceptos, lo siguiente: "(...)".

SEGUNDO: El 30 de octubre de 2022 *****EMAIL.1**" envió un correo electrónico a *****EMAIL.2**, con copia a *****EMAIL.3; ***EMAIL.4; ***EMAIL.5; ***EMAIL.6; ***EMAIL.7; ***EMAIL.8; ***EMAIL.9**".

Este correo electrónico tenía como asunto “Re: (...)” y a él se acompañan diez imágenes con documentación bancaria grapada, consistente en un cuadro de amortización de un préstamo, cuyo titular es **B.B.B.**, figurando en algunos documentos anotaciones manuscritas indicando “Pagado por mí” y “Las deudas pendientes fueron pagadas por **C.C.C.** (...)”

TERCERO: La dirección de correo electrónico utilizada para el envío de tales correos electrónicos no corresponde a ningún dominio del Grupo BBVA, es una dirección personal.

CUARTO: El 3 de marzo de 2020 (fecha del extracto de la cuenta) se realizó desde la oficina (...) situada en *****DIRECCIÓN.1**, que no se corresponde con la oficina gestora de la cuenta, una consulta de movimientos de la cuenta **IBAN ES0000000000000000000000**. El usuario que figura en el registro de la transacción, y que por tanto accedió a la consulta de saldo y movimientos de la cuenta, corresponde a **C.C.C.**, empleado de BBVA desde el 16/03/1992 al 01/08/2021, fecha de efecto de la baja voluntaria incentivada con motivo de su adscripción al ERE (Expediente de Regulación de Empleo).

QUINTO: BBVA cuenta con un documento sin fecha ni firma ni indicación de versión a la que corresponde, con el título "Protocolo de Protección de Datos Data Protection Office (DPO)". En este documento se observa, entre otro, el siguiente contenido:

- “(. . .)”
- “(. . .)”
- “(. . .)”

SEXTO: BBVA facilitó el 12 de marzo de 2018 información a sus empleados mediante un boletín de noticias denominado “Hoy” que incluye un enlace documento “Protocolo de Protección de Datos y Experiencia Cliente”. En este boletín se observa, entre otro, el siguiente contenido:

“(...)”

SÉPTIMO: BBVA cuenta con un documento titulado “Código de Conducta del Grupo BBVA”, sin fecha ni firma ni indicación de versión, en el que se observa, entre otro, el siguiente contenido:

- (...)
- (...)

- (...)

- (...)

- (...)

- (...)

OCTAVO: BBVA cuenta con un canal de consulta por las posibles dudas que pudieran surgir en relación con la aplicación del “Código de Conducta del Grupo BBVA”, con el siguiente contenido:

“(…).”

NOVENO: BBVA tiene un canal de denuncia a disposición de sus empleados para comunicar conductas que supongan un incumplimiento del Código de Conducta, en el que puede verse:

“(…).”

DÉCIMO: Los empleados de BBVA que se adscribieron al ERE formalizaron con la Entidad una “Carta de Despido” en la que se incluía la obligación de confidencialidad y de guardar el secreto profesional.

DÉCIMO PRIMERO: BBVA cuenta con un documento titulado “Política General de Privacidad y Protección de Datos” establecida por el Consejo de Administración de BBVA, sin firmar, primera versión del documento, de fecha 28 de septiembre de 2022, con el siguiente contenido, entre otro:

“(…).”

DÉCIMO SEGUNDO: BBVA cuenta con un documento titulado “Norma corporativa de protección de datos personales”, sin firmar, primera versión del documento, de fecha 19 de mayo de 2023, con (entre otro) el siguiente contenido:

“(…).”

DÉCIMO TERCERO: BBVA cuenta con un documento titulado “Norma de protección de datos de carácter personal”, sin firmar, versión 8, de fecha 1 de abril de 2022, en el que puede verse, entre otro, el siguiente contenido:

“(…).”

DÉCIMO CUARTO: BBVA dispone de medios que le permiten verificar los accesos de los usuarios a los datos personales de sus clientes, que permiten obtener información sobre la fecha, hora del acceso, dirección IP y usuario asociado, lo cual permitió al BBVA saber que **C.C.C.** había sido quien accedió la información de los productos de **A.A.A.** del banco.

DÉCIMO QUINTO: Los datos de **B.B.B.** figuran bloqueados LOPD como consecuencia de la cancelación de todos los productos en BBVA en el mes de diciembre de 2020 y no tiene contratos activos desde esa fecha.

DÉCIMO SEXTO: **C.C.C.** ha recibido desde BBVA formación desde el año 2018, y entre otros cursos figuran:

- (...)
- (...)
- (...)
- (...)

DÉCIMO SÉPTIMO: Según consta en el “Informe Anual 2022”, publicado en https://accionistaseinversores.bbva.com/wp-content/uploads/2023/03/Informe-Anual-BBVA_2022_esp.pdf, en el año 2022 el beneficio de BBVA ha ascendido a 6.420 millones de euros, y contaba con más de 89 millones de clientes, según consta en la diligencia que se incorpora al expediente de fecha 9 de febrero de 2024.

FUNDAMENTOS DE DERECHO

I

Competencia y procedimiento

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos.”*

II

Cuestiones previas

En el presente caso, de acuerdo con lo establecido en el artículo 4.1 y 4.2 del RGPD, consta la realización de un tratamiento de datos personales, toda vez que BBVA realiza la recogida y conservación de, entre otros, los siguientes datos personales de

personas físicas: nombre y apellido y número de cuenta bancaria, entre otros tratamientos.

BBVA realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD.

III

Alegaciones aducidas

En relación con las alegaciones aducidas al acuerdo de inicio del presente procedimiento sancionador, se procede a dar respuesta a las mismas según el orden expuesto por BBVA:

PRIMERA. – DE LOS HECHOS ACAECIDOS EN EL PRESENTE CASO

Resume BBVA los hechos acaecidos del siguiente modo:

- El 30/10/22 **C.C.C.** envía un correo electrónico a diversos destinatarios, todos ellos según se deduce de los apellidos que mantienen en común, familiares, en el que se adjunta determinada información bancaria de **A.A.A.**
- Según consta en el expediente dicho email parece provenir de **C.C.C.** pero de una dirección ajena a BBVA, ya que el dominio de la misma es “(...)”.
- **C.C.C.** NO es empleado de BBVA desde el 01/08/21, momento en el que se desvincula de la Entidad con motivo de su adscripción al ERE correspondiente.
- Es decir, al momento de enviarse el citado email con, supuestamente, la información bancaria de **A.A.A.**, **C.C.C.** ya no mantenía ninguna relación laboral con BBVA.
- **C.C.C.** en fecha 3 de marzo de 2020 accedió a los datos bancarios de su madre, la reclamante.

De estos hechos, se desprende, a juicio de BBVA, lo siguiente:

- NO existe prueba alguna de que el acceso de **C.C.C.** a las posiciones de la **A.A.A.**, su madre (a entender de BBVA), fuera no consentido. Habida cuenta que **C.C.C.** no es empleado de BBVA no se ha podido escuchar su versión de los hechos por lo que NO se ha podido acreditar a qué obedeció el acceso a las posiciones de **A.A.A.**. Perfectamente pudo haber sido a petición suya o a petición de los diversos apoderados que su madre, **A.A.A.**, había determinado.
- No existe prueba alguna de que **C.C.C.** descargase documento bancario alguno de **A.A.A.**. Solo se ha acreditado la consulta a las posiciones de **A.A.A.** pero NO se ha acreditado descarga de documento alguno por parte de **C.C.C.**

- Tampoco se ha acreditado que, en caso de haberse descargado algún documento, dicho documento fuera precisamente el que supuestamente se envía DOS AÑOS DESPUES por medio de un correo electrónico.

- Del mismo modo NO se acredita ni el contenido real del email pues lo que se aporta y consta en el expediente es el reenvío de un correo electrónico el cual puede ser manipulado ni se acredita que en dicho correo electrónico hubiera anexado ningún documento pues no existe referencia alguna al mismo en el cuerpo del escrito.

- No existe prueba ni indicio alguno que determine que el documento que se adjunta a la reclamación estuviera anexo al citado correo electrónico puesto que el asunto del mismo es "(...)" y el documento que se aporta junto con la reclamación data de 2020.

- NO existe nexo causal entre el acceso de **C.C.C.** a la información bancaria de la reclamante (acceso que no ha quedado acreditado que no fuera consentido) y el envío de un correo electrónico dos años después con, supuestamente, información bancaria de la reclamante.

Al respecto, esta Agencia desea señalar que no consta acreditado que **A.A.A.** fuera familiar de **C.C.C.** ni mucho menos que sea su madre. Este extremo ha sido inferido por BBVA sin que constara en el expediente.

Consta acreditado, tal y como señala BBVA en sus alegaciones, que el 30 de octubre de 2022 **C.C.C.** envió un correo electrónico a diversos destinatarios, en el que se adjunta información bancaria de **A.A.A.** Y que el 3 de marzo de 2020 **C.C.C.**, empleado de BBVA en ese momento, accedió a información financiera de **A.A.A.** sin que estuviera autorizado por **A.A.A.** y sin que fuera ello necesario en atención a sus funciones.

El hecho de que utilizara para ello una dirección ajena a BBVA es completamente irrelevante a los fines del presente procedimiento sancionador. Ni tampoco el hecho de que al enviar el correo electrónico con información financiera de **A.A.A.** ya no fuera empleado de BBVA, si bien lo era al momento en que se obtuvo tal información que fue enviada posteriormente por correo electrónico.

En cuanto a que el acceso a los datos financieros de **A.A.A.** por parte de **C.C.C.** pudiera haber sido consentido, esta Agencia desea recordar que la propia reclamación presentada por **A.A.A.** ya indica que éste no estaba autorizado a acceder a dicha información, ya que **A.A.A.** presentó un poder notarial indicando que solo sus tres apoderados podían tener acceso a su cuenta y ninguno de estos apoderados correspondía con **C.C.C.** Además, no consta en el presente procedimiento que el banco tuviera poder alguno que habilitara al acceso de los datos personales de **A.A.A.** por parte de **C.C.C.** Y aun en el supuesto de que hubiera sido información solicitada por **A.A.A.** o sus apoderados, tampoco ello habría permitido a **C.C.C.** a obtener copia de esta información y a utilizarla para sus propios intereses personales, como ha ocurrido.

Alega BBVA que no existe prueba de que el 3 de marzo de 2020 **C.C.C.** hubiera descargado la información sobre **A.A.A.** ni que ese documento hubiera sido el enviado en el correo electrónico de 30 de octubre de 2022, ni que el contenido real del email

fuera ese, toda vez que puede manipularse la copia presentada a la Agencia y que no existe referencia a un documento anexo al correo en el cuerpo del mismo. Tampoco habría quedado acreditado que el documento anexo al correo fuera el adjunto a la reclamación, ya que el asunto del correo es “(...)” y el documento supuestamente adjunto data de 2020. Por lo que considera no acreditado la relación causal entre el acceso de **C.C.C.** a la información bancaria de la reclamante y el envío del correo electrónico en cuestión, dos años después.

Al respecto, esta Agencia desea señalar que es irrelevante que **C.C.C.** hubiera descargado o no la información consultada sobre **A.A.A.** el 3 de marzo de 2020, bastaba con hacer una captura de la imagen de tal información, que es lo que se adjunta a la reclamación.

En cuanto a que no existe una referencia a un documento anexo al correo en el cuerpo del mismo, ello es irrelevante a los fines del presente procedimiento sancionador. Esta Agencia considera que la información financiera de **A.A.A.** del año 2020 se acompaña al correo de 2022, ya sea como adjunto o como simple imagen incorporada al cuerpo del correo electrónico. Y para ello es completamente irrelevante si el asunto del correo menciona el año 2022 y la información que se acompaña es del año 2020.

En definitiva, esta Agencia considera debidamente acreditado el nexo causal entre el acceso de **C.C.C.** a la información bancaria de **A.A.A.** y el envío del correo electrónico con tal información el 30 de octubre de 2022.

En todo caso, el objeto del presente procedimiento es que BBVA no contaba con las medidas técnicas y organizativas adecuadas a fin de evitar que un empleado de la entidad obtuviera datos personales de quien no podía ni visualizarlos en atención a sus funciones y clientes.

Por lo que se desestima la presente alegación.

SEGUNDA. - SOBRE LA PRETENDIDA VULNERACIÓN POR BBVA DEL ARTÍCULO 32 DEL RGPD

1. Sobre el contenido del Acuerdo de Inicio

BBVA alega que cuentan con medidas de seguridad para asegurar la confidencialidad de los sistemas y servicios de tratamiento y que dirigen información y formación a sus empleados.

Se traen a colación los siguientes documentos, ya aportados previamente:

- “Protocolo de Protección de Datos y Experiencia Cliente” realizado en colaboración con el Departamento de Data Protección Office (DPO) y que contiene recomendaciones sobre cómo tratar los datos personales de clientes con la seguridad y confidencialidad. El protocolo se encuentra en la intranet de interna de la Entidad por lo que es accesible a los empleados.
- Información a los empleados mediante un boletín de noticias denominado “Hoy” facilitada el lunes 12 de marzo de 2018, que incluye un enlace al

(...)

- “Código de Conducta del Grupo BBVA” que recoge la obligación de los empleados de guardar y mantener la confidencialidad de los datos que traten. Además, se obligarán a no difundir, transmitir o revelar a terceros cualquier información relacionada o datos a que tengan acceso como consecuencia del desempeño de su actividad, ni a utilizar tal información en interés propio. Esta obligación subsistirá aún finalizada la relación contractual. Se acompaña captura de pantalla con el siguiente contenido:

“(...)”.

Se acompaña también captura de pantalla del aplicativo interno con acceso a un canal de consulta por las posibles dudas que pudieran surgir en relación con la aplicación de dicho código, con el siguiente contenido:

“(…).”

Además, BBVA tiene establecido un canal de denuncia a disposición de sus empleados para comunicar conductas que supongan un incumplimiento del Código de Conducta. Se acompaña una captura de pantalla con el siguiente contenido:

“(...)”.

- “Carta de Despido”. Los empleados que se adscribieron al ERE –como es el caso de **C.C.C.**- formalizaron con la Entidad una en la que se incluía la obligación de confidencialidad y de guardar el secreto profesional.
- Certificado que incluye la formación registrada desde el año 2018 por parte del ex empleado **C.C.C.** que, entre otros, figura la realización de los siguientes cursos:

- (...) **...**

- (...) **...**

- (...) **...**

- (...) **...**

Por su parte, BBVA aporta nuevos documentos sobre las medidas de seguridad establecidas para asegurar la confidencialidad de los sistemas y servicios de tratamiento y la información y formación dirigidas a sus empleados:

- **DOCUMENTO N° 1:** “Política General de Privacidad y Protección de Datos” establecida por el Consejo de Administración de BBVA, con objeto de velar por

la privacidad y la protección de los datos que conciernen a las personas físicas y jurídicas que se relacionan con BBVA, y las diferentes sociedades que componen el Grupo. Se acompaña captura de pantalla sobre el principio de confidencialidad integrado en dicho documento, como uno de los valores del Grupo BBVA:

“(…)”

- **DOCUMENTO Nº 2:** “Norma corporativa de protección de datos personales”, documento que alude al secreto profesional. Se acompaña captura de pantalla con el siguiente contenido:

“(…)”

- **DOCUMENTO Nº 3:** “Norma Protección de datos de carácter personal” de aplicación a cualquier tratamiento de datos de carácter personal que se lleve a cabo, con independencia del colectivo al que pertenezcan los datos: clientes, no clientes, empleados, accionistas, apoderados, etc., en todas las unidades que conforman la geografía de España sujetas al cumplimiento de los requisitos regulatorios del país. El contenido de esta norma se recuerda de forma habitual a los empleados mediante campañas de información. Se acompaña capturas de pantalla con el siguiente contenido:

“(…)”

- **DOCUMENTO Nº 4:** “Política de protección de datos personales derivados de tu relación laboral” documento que recoge la obligación de confidencialidad de los empleados. Se acompaña capturas de pantallas con el siguiente contenido:

“(…)”.

Por último, en relación con las medidas que tiene BBVA dirigidas a los empleados en relación con la protección de datos personales, indica que dispone de medios que le permiten verificar los accesos de los usuarios a los datos personales de sus clientes. Estos registros de inicio de sesión, de acceso a archivos o actividad de usuarios, han permitido al Departamento de Auditoría Interna de la Entidad obtener información sobre la fecha, hora del acceso, dirección IP y usuario asociado a la información de los productos de la reclamante en BBVA.

Explica BBVA que el registro de accesos es una medida para garantizar la seguridad adecuada de los datos personales tratados ya que permite identificar al empleado del Grupo que consulta. Es, por tanto, una medida de disuasión y prevención de posibles accesos injustificados.

Por lo expuesto, entiende BBA que la afirmación que realiza la AEPD cuando manifiesta que BBVA *no contaba con las medidas de seguridad de índole técnico y organizativo suficientes*, no se corresponde a la realidad de los hechos, dado que BBVA sí cuenta medidas técnicas y organizativas, resultantes de un adecuado análisis de los riesgos que el tratamiento puede generar en los derechos de los interesados.

A tal efecto y según se desprende de lo hasta ahora expuesto, alega BBVA que tiene establecidas medidas como:

- Políticas claras. Según se acredita con la documental obrante en el expediente, así como con la aportada junto con las presentes alegaciones, BBVA ha proveído las directrices a seguir por las distintas áreas de negocio para la implementación de medidas de seguridad sobre los Sistemas de Información propiedad de BBVA, basadas en la clasificación de la información que manejan y adecuados a la valoración de los riesgos en materia de protección de datos y seguridad a los que están expuestos.
- Acceso restringido. BBVA permite el acceso a datos personales de clientes exclusivamente a aquellos empleados que precisan disponer de dichos datos para el ejercicio de las funciones propias de su cargo.
- Monitoreo y auditoría. BBVA dispone de medidas de control de los accesos de sus empleados a los datos personales de los clientes con la finalidad de realizar una adecuada labor de prevención y supervisión.
- Formación y concienciación. BBVA realiza regularmente cursos de formación a sus empleados sobre las políticas de seguridad para garantizar una conciencia colectiva sobre la importancia de realizar un tratamiento de datos personales seguro. Todo ello ayuda a garantizar la seguridad adecuada en el tratamiento de datos personales.
- Denuncias y canales de comunicación. BBVA tiene establecidos mecanismos para que los empleados puedan informar de manera confidencial sobre cualquier actividad sospechosa o inapropiada de la que sean conocedores con el fin de detectar y minimizar riesgos.

Alega BBVA que ha desplegado una actividad diligente en la implantación de las mencionadas medidas, que pueden calificarse de idóneas y suficientes para garantizar la seguridad adecuada de los datos personales que trata, si bien, no se le puede exigir una obligación de resultado ante comportamientos indeseados ajenos a cualquier control. Y que las medidas establecidas por la Entidad garantizan un nivel de seguridad adecuado al riesgo, además de fomentar un entorno de trabajo ético que promueve valores de integridad y responsabilidad entre los empleados.

Por otra parte, debe tenerse en cuenta que las medidas de seguridad que pudieran resultar del análisis de los riesgos derivados del tratamiento de datos han de añadirse las derivadas de la aplicación de las normas sectoriales que resultan de especial aplicación a BBVA en su condición de entidad de crédito (cita el art. 83 de la Ley 10/2014, de 26 de junio, de ordenación, supervisión y solvencia de entidades de crédito, que impone a las entidades de crédito el deber de guardar reservada las informaciones relativas a los saldos, posiciones, transacciones y demás operaciones de sus clientes, si bien, tal reserva tiene sus propios límites: sin que las mismas(informaciones) puedan ser comunicadas a terceros u objeto de divulgación).

En segundo lugar, BBVA considera errónea la interpretación efectuada por la AEPD de lo dispuesto en el RGPD cuando indica que *“No es suficiente con que BBVA, como*

responsable del tratamiento, implante medidas de seguridad, sino que también, debe asegurar su cumplimiento.”

Alega que la AEPD considera que la vigente normativa de Protección de Datos impone, en lo que respecta a la adopción de medidas de seguridad, una obligación de resultado, entendiendo BBVA que el evidente espíritu del legislador, al establecer el Principio de Responsabilidad Proactiva, es promulgar una obligación de medios.

En este sentido, cita la sentencia del Tribunal Supremo de 15 de febrero de 2022 (recurso de casación 7359/2020) que señala de forma clara que la obligación impuesta por la normativa de protección de datos personales, de adoptar medidas técnicas y organizativas encaminadas a garantizar la confidencialidad, disponibilidad e integridad de la información, es una obligación de medios y no de resultado, como tradicionalmente venía considerando la AEPD y respaldando la doctrina de la Audiencia Nacional.

Consecuencia de todo lo anterior es que BBVA concluye que las premisas que sientan el juicio de valoración de las circunstancias del caso y que conducen a la AEPD a la imposición de la infracción por la supuesta vulneración del artículo 32 del RGPD decaen ante la realidad de los hechos, lo que necesariamente debería conducir al archivo del presente expediente.

Al respecto, esta Agencia desea señalar que en ningún momento había entendido que BBVA no contara con ninguna medida para asegurar la confidencialidad de los datos personales de sus clientes. Tampoco en su acuerdo de inicio ha indicado que la obligación del artículo 32 del RGPD fuera una obligación de resultado.

El propio acuerdo de inicio del presente procedimiento sancionador reconocía que BBVA contaba con medidas, pero que éstas no eran “suficientes para evitar que se produjera una violación de seguridad de los datos personales de clientes, datos de los que el banco es titular.” Y que: “Si bien es cierto que BBVA disponía de algunas medidas dirigidas a los empleados en relación con la protección de datos personales, como proporcionar información y formación; resulta evidente que son insuficientes para evitar un incidente similar a la cuestión que dio origen al presente procedimiento. Además, tampoco es suficiente con que BBVA, como responsable del tratamiento, implante medidas de seguridad, sino que también, debe asegurar su cumplimiento.”

BBVA indica en sus alegaciones una serie de medidas que tiene implementadas para evitar la vulneración de los datos personales de sus clientes por parte de sus empleados. Principalmente se trata de proporcionar información a sus empleados sobre sus obligaciones de confidencialidad y sobre lo que no están autorizados a hacer. Y también proporcionar información a través de formación sobre el tema.

Al respecto, los documentos aportados por BBVA o no indican fecha en que fueron adoptados o llevan fecha posterior al acceso de los datos personales de A.A.A. por parte de C.C.C. en el año 2020, cuando aún era empleado de BBVA:

- Protocolo de Protección de Datos Data Protection Office (DPO)”: no se indica fecha
- “Código de Conducta del Grupo BBVA”: no se indica fecha

- “Política General de Privacidad y Protección de Datos”: de fecha 28 de septiembre de 2022
- Norma corporativa de protección de datos personales”: de fecha 19 de mayo de 2023
- Norma de protección de datos de carácter personal”: de fecha 1 de abril de 2022

Antes del año 2020, solo se indica que **C.C.C.** ha recibido desde BBVA formación desde el año 2018 y que el 12 de marzo de 2018 se proporcionó información a los empleados de BBVA mediante un boletín de noticias denominado “Hoy” con un enlace al documento “Protocolo de Protección de Datos”, pero no se aporta información sobre si tal boletín era de lectura obligatoria para esos empleados o si dichos empleados accedieron a su contenido y al citado protocolo.

En toda la documentación aportada por BBVA en sus escritos de respuestas a los traslados de las reclamaciones y respuesta a requerimientos de información de esta Agencia y en su escrito de alegaciones, en ningún momento se aporta información sobre medidas para garantizar que tales obligaciones sean cumplidas por parte de sus empleados.

La única medida en este sentido sería el mencionado control de registros de inicio de sesión, de acceso a archivos o actividad de usuarios, que permite verificar los accesos de los usuarios a los datos personales de los clientes y que es lo que ha permitido en este caso al Departamento de Auditoría Interna de BBVA conocer que el 3 de marzo de 2020 (fecha del extracto de la cuenta) se realizó desde la oficina (...) situada en *****DIRECCIÓN.1**, que no se corresponde con la oficina gestora de la cuenta, una consulta de movimientos de la cuenta **IBAN ES0000000000000000000000**. Y que el usuario que figuraba en el registro de la transacción, y que por tanto accedió a la consulta de saldo y movimientos de la cuenta, correspondía a **C.C.C.**, empleado de BBVA desde el 16/03/1992 al 01/08/2021, fecha de efecto de la baja voluntaria incentivada con motivo de su adscripción al ERE (Expediente de Regulación de Empleo).

No obstante, esta información solo resultó de utilidad una vez se tuvo conocimiento de las reclamaciones objeto del presente procedimiento, no fue utilizada con anterioridad, ni tampoco consta acreditado en el expediente que existieran procedimientos para controlar que todo lo detallado en los documentos facilitados a los empleados se cumpla ni que existieran controles para ello que se llevaran a cabo por la entidad de forma regular.

Si bien el banco contaba con medidas para lograr la trazabilidad de quien había accedido a los datos personales de sus clientes, no consta en el presente procedimiento que se realizaran auditorías o revisiones posteriores por, por ejemplo, una denuncia, ni que se hubiera implementado medidas técnicas y organizativas apropiadas para que cada empleado pudiera acceder solamente a los datos personales de aquellos clientes que tuviera asignado en un momento determinado e impedir que cualquier empleado pudiera acceder a los datos personales de cualquier cliente.

No hay medidas preventivas previas en el presente caso. No se atiende al enfoque de riesgos del RGPD ni a su carácter preventivo.

En virtud del artículo 5.2 del RGPD es obligación de BBVA: “El responsable del tratamiento será responsable del cumplimiento de lo dispuesto en el apartado 1 y capaz de demostrarlo («responsabilidad proactiva»).

En ninguno de sus escritos presentados, ni en los escritos de 17 de marzo de 2023 de respuesta a los traslados de las reclamaciones, ni en los escritos de 21 de junio de 2023 ni 21 de agosto de 2023 de respuesta a requerimiento de esta Agencia, ni en su escrito de alegaciones de 8 de marzo de 2024, se ha aportado información sobre que se hubieran adoptado medidas para asegurar el cumplimiento de todo lo incorporado en la documentación reseñada. Lo cual no puede entenderse por esta Agencia como una obligación (de medios) debidamente cumplida por parte de BBVA.

Por todo lo expuesto, se desestima la presente alegación.

2. Sobre la ausencia de nexo causal entre el acceso a los datos **A.A.A.** por parte de **C.C.C.**

Insiste BBVA en que “ni del relato fáctico de la reclamación ni de la documental obrante en el Expediente o de la prueba practicada por la AEPD, se desprende que **C.C.C.** descargara información alguna de la reclamante y que esa misma información fuera la que, dos años después, enviara aparentemente sin consentimiento de la reclamante a diversos destinatarios”.

Insiste en que en el expediente consta que **C.C.C.**, en el ejercicio de sus funciones como empleado de BBVA –se desconoce, pues no se ha preguntado a terceros, si incluso bajo mandato de la reclamante o alguno de los autorizados en sus productos– accedió en fecha 3 de marzo de 2020 a la cuenta de la reclamante.

Y que no ha quedado acreditado:

- **(i)** que dicho acceso no fuera consentido o conocido por la reclamante
- **(ii)** que **C.C.C.** efectuara algún tipo de descarga de documentos durante dicho acceso
- **(iii)** que los supuestos documentos descargados en 2020 fueran, además, los que se enviaron por email (ajeno a la Entidad, tanto la dirección de correo electrónico como **C.C.C.** que ya no era empleado de BBVA) a diversos destinatarios
- **(iv)** que los documentos incluidos en la reclamación fueran los adjuntos al citado correo habida cuenta que en el mismo se hace referencia a “donación mama noviembre 2022” y el documento que se adjunta es del año 2020.

Alega BBVA que sin haber sido escuchado **C.C.C.** y sin existir prueba alguna de que en marzo de 2020 el mismo descargara ningún tipo de información de la reclamante, la AEPD con su pronunciamiento está vulnerando el principio de presunción de inocencia

principio aplicable al derecho administrativo sancionador (cita sentencias del Tribunal Supremo de 29 de septiembre, 4 y 10 de noviembre de 1980, y STC 18/1981).

Y que también es de aplicación el principio de culpabilidad o responsabilidad subjetiva, debido a que es considerada esencial para la existencia del ilícito administrativo (cita STC 76/1990 de 26 de abril, SST de 22 de febrero de 1992 y 5 de junio de 1989 y STS de 9 de julio de 1994).

Insiste BBVA que NO ha quedado acreditado que **C.C.C.** sea culpable de la descarga indebida de los datos enviados mediante email habida cuenta que no existe prueba de la descarga de dicha información en fecha 3 de marzo de 2020 pudiendo ser –si es que fueron– los extractos enviados por email, dos años después, documentos obtenidos fuera del ámbito de su relación laboral (ya extinguida en 2021) con BBVA (pueden ser documentos obtenidos en el domicilio de su madre, que se los haya facilitado algún familiar, etc.).

Y alega BBVA que en el caso que nos ocupa ni siquiera ha quedado acreditada la infracción (pues no consta prueba alguna de descarga de los documentos por parte de **C.C.C.** ni consta prueba alguna de que el acceso a los datos de la reclamante no fuera consentido por ésta) por lo que tampoco ha podido quedar acreditada la concurrencia de dolo o culpa respecto de la misma.

Insiste en que cuando una persona decide reenviar un email el mismo puede ser objeto de modificaciones al libre albedrío de la persona que lo reenvía por lo que no existe constancia de que el email enviado por **C.C.C.** el 15 de noviembre de 2022 contuviera ni el texto que la reclamante manifiesta ni que se adjuntara documento alguno al mismo ya que, como se acredita a continuación, cuando se envía un correo electrónico que contiene un archivo adjunto aparece un símbolo arriba a la derecha (en forma de “clip”) que justifica el envío de un archivo adjunto. Se adjunta una captura de pantalla de un correo electrónico en el que se encuentra resaltado en amarillo la imagen de un clip, en la esquina derecha superior.

Y alega BBVA que en el caso que nos ocupa, del email reenviado, NO se desprende que existiera un archivo adjunto al mismo. Se copia captura de pantalla del correo electrónico enviado por **C.C.C.** en el que no aparece tal clip en la parte superior derecha.

Insiste BBVA en que el correo electrónico lleva por asunto “(...)” y el documento que supuestamente se adjunta data de 2020 por lo que decae nuevamente cualquier indicio de culpabilidad de **C.C.C.** respecto del asunto y, en consecuencia, la responsabilidad de BBVA.

Por ello, insiste BBVA, no existe prueba alguna:

- **(i)** del envío de la documentación que se aporta junto con la reclamación pues ni siquiera el asunto del correo y la documentación aportada por la reclamante guardan nexo alguno, por parte de **C.C.C.**
- **(ii)** ni de que dicha documentación, en el caso de haber sido efectivamente enviada fuera descargada por **C.C.C.** en el ejercicio de sus funciones en BBVA.

Dado que estas alegaciones son las mismas que se contestaron anteriormente, esta Agencia se reitera en lo ya expuesto en las respuestas a tales alegaciones y en los hechos considerados como probados de la presente resolución.

Por lo que se desestima la presente alegación.

3. Respetto de la reclamación relativa a los datos de **B.B.B.**

Indica BBVA que presenta alegaciones sobre la reclamación interpuesta por **B.B.B.**, pese a que la misma cursa con un número de expediente diferente al que nos ocupa, habida cuenta de la continua referencia al mismo que se hace en el presente procedimiento.

Al respecto, esta Agencia desea señalar que el presente procedimiento sancionador tiene su origen en dos reclamaciones: la presentada por **A.A.A.** el 15 de noviembre de 2022 y la presentada por **B.B.B.** el 17 de noviembre de 2022, y que se han acumulado en el presente procedimiento sancionador y así se reflejaba ya en el acuerdo de inicio del presente procedimiento.

Respetto de la reclamación presentada por **B.B.B.**, BBVA alega:

- Respetto del acceso por parte de **C.C.C.** a los datos de **B.B.B.**. Como quedó acreditado a requerimiento de la AEPD, en el periodo transcurrido entre el 1/01/2022 al 30/10/2022, no hay accesos a aplicaciones informáticas de los datos de **B.B.B.**. Por ello, NO se acredita si quiera el acceso a los datos de **B.B.B.** por parte de **C.C.C.**
- Respetto a los documentos que supuestamente constan en el email enviado por **C.C.C.** en 2022:
 - (i) las tres primeras imágenes parece que se trata de la validación mecánica de ingresos en cuenta, de ser así la persona que realiza el ingreso recibe copia del resguardo del ingreso por lo que no queda acreditado nuevamente el acceso a dicha documentación por parte de **C.C.C.**
 - (ii) la tercera imagen es ilegible, parece una captura de pantalla del aplicativo de BBVA.
 - (iv) las imágenes quinta, sexta y séptima parece que se corresponden con un cuadro de amortización de un préstamo (cuotas desde el 2003 hasta el 2013); no existe un nexo causal entre estas imágenes y la alegada por el reclamante cesión de datos no consentida por parte de BBVA.
 - No se evidencia que el acceso a la documentación aparentemente del año 2008 y 2013, se haya facilitado por BBVA a un tercero distinto del titular. Cualquier documento que se corresponda, por ejemplo, como en este caso, con un cuadro de amortización de un préstamo, en manos de

un tercero diferente del titular, no implica que se trate de una vulneración a la protección de datos del cliente por parte de la Entidad, ya que el acceso al documento una vez que se entrega al cliente en la formalización de la operación se escapa del control del Banco.

Al respecto, esta Agencia desea señalar que el hecho de que los datos no fueran consultados en dicho período de 2022 no significa que **C.C.C.** no pudiera haberlos obtenido con anterioridad. Lo que sí queda acreditado en el expediente es que **C.C.C.**, ex empleado de BBVA, había obtenido tal información cuando sí era empleado del banco y la utilizó para sus propios intereses.

Y que esta Agencia considera que sí existe nexo causal suficiente entre el acceso a la información por parte de **C.C.C.**, por cuanto era empleado de BBVA, y su utilización para sus propios intereses, al haberla compartido con terceros mediante un correo electrónico de 15 de noviembre de 2022.

Por último, BBVA se reitera en las alegaciones vertidas respecto del reenvío de un correo electrónico, la vulnerabilidad de su contenido una vez se reenvía éste y la ausencia de acreditación de que en dicho correo electrónico existieran archivos adjuntos, por lo que esta Agencia se reitera en su respuesta a tales alegaciones proporcionada anteriormente.

Por todo lo expuesto, se desestima la presente alegación.

IV

Seguridad del tratamiento

El artículo 32 “Seguridad del tratamiento” del RGPD establece:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;*
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;*
- d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.*

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros.”

En el presente caso, BBVA no contaba con las medidas de seguridad de índole técnico y organizativo suficientes para evitar que se produjera una violación de seguridad de los datos personales de clientes, datos de los que el banco es titular.

Si bien el banco contaba con medidas para lograr la trazabilidad de quien había accedido a los datos personales de sus clientes, no consta en el presente procedimiento que se realizaran auditorías o revisiones posteriores por, por ejemplo, una denuncia, ni que se hubiera implementado medidas técnicas y organizativas apropiadas para que cada empleado pudiera acceder solamente a los datos personales de aquellos clientes que tuviera asignado en un momento determinado e impedir que cualquier empleado pudiera acceder a los datos personales de cualquier cliente.

No hay medidas preventivas previas en el presente caso. No se atiende al enfoque de riesgos del RGPD ni a su carácter preventivo.

Si bien es cierto que BBVA disponía de algunas medidas dirigidas a los empleados en relación con la protección de datos personales, como proporcionar información y formación; resulta evidente que son insuficientes para evitar un incidente similar a la cuestión que dio origen al presente procedimiento. Además, tampoco es suficiente con que BBVA, como responsable del tratamiento, implante medidas de seguridad, sino que también, debe asegurar su cumplimiento.

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de resolución de procedimiento sancionador, se considera que los hechos conocidos son constitutivos de una infracción, imputable a BBVA, por vulneración del artículo transcrito anteriormente.

V

Tipificación y calificación de la infracción del artículo 32 del RGPD

La citada infracción del artículo 32 del RGPD supone la comisión de una de las infracciones tipificadas en el artículo 83.4 del RGPD que bajo la rúbrica “*Condiciones generales para la imposición de multas administrativas*” dispone:

“4. Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del

volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...)"

A efectos del plazo de prescripción de las infracciones, la infracción imputada prescribe a los dos años, conforme al artículo 73 de la LOPDGDD, que califica de grave la siguiente conducta:

"En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

(...)

f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679. (...)"

VI

Sanción por la infracción del artículo 32 del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de resolución de procedimiento sancionador, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD:

Como agravantes:

- La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (apartado a): por no contar con las medidas de seguridad apropiadas al riesgo de que se produjera una violación de la seguridad de los datos personales como la que ha tenido lugar en el presente caso, que permitió que se hiciera un tratamiento indebido de varios documentos con datos de dos afectados.

- Toda infracción anterior cometida por el responsable o el encargado del tratamiento (apartado e): en esta Agencia constan dos procedimientos sancionadores (PS/00419/2022 y PS/00429/2022) en los que se adoptaron decisiones de resolución en fecha 28/09/2022 y 11/11/2022. En ambos casos, se le imputó a BBVA la infracción del artículo 32 del RGPD.

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “*Sanciones y medidas correctivas*” de la LOPDGDD:

Como agravantes:

- La vinculación de la actividad del infractor con la realización de tratamientos de datos personales (apartado b): BBVA, entidad financiera, y el elevado número de clientes con el que cuenta, conlleva el manejo de un gran número de datos personales. No contar con las medidas técnicas y organizativas adecuadas a fin de impedir que los empleados del banco puedan acceder a los datos personales de los clientes aún sin estar autorizados para ello ni ser necesario para sus funciones, implica un riesgo para la privacidad de los datos de todos los clientes del BBVA.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 32 del RGPD, permite fijar una sanción de multa administrativa de 70.000 euros.

VII

Imposición de medidas

De acuerdo con lo establecido en el citado artículo 58.2 d) del RGPD, según el cual cada autoridad de control podrá “*ordenar al responsable o encargado del tratamiento que las operaciones de tratamiento se ajusten a las disposiciones del presente Reglamento, cuando proceda, de una determinada manera y dentro de un plazo especificado...*”, se requiere a BBVA para que en el plazo de seis meses acredite ante esta Agencia la adopción de las medidas necesarias para garantizar el cumplimiento de lo dispuesto en el artículo 32 del RGPD, a fin de evitar que se produzca un incidente similar al que dio origen al presente procedimiento.

La imposición de estas medidas es compatible con imponer una multa administrativa, según lo dispuesto en el artículo 83.2 del RGPD.

Se advierte que no atender la posible orden de adopción de medidas impuestas por este organismo en la resolución que ponga fin al presente procedimiento podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como infracción en su artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

VIII

Terminación del procedimiento

El artículo 85 de la LPACAP, bajo la rúbrica “*Terminación en los procedimientos sancionadores*” dispone lo siguiente:

“1. Iniciado un procedimiento sancionador, si el infractor reconoce su responsabilidad, se podrá resolver el procedimiento con la imposición de la sanción que proceda.

2. Cuando la sanción tenga únicamente carácter pecuniario o bien quepa imponer una sanción pecuniaria y otra de carácter no pecuniario pero se ha justificado la improcedencia de la segunda, el pago voluntario por el presunto responsable, en cualquier momento anterior a la resolución, implicará la terminación del procedimiento, salvo en lo relativo a la reposición de la situación alterada o a la determinación de la indemnización por los daños y perjuicios causados por la comisión de la infracción.

3. En ambos casos, cuando la sanción tenga únicamente carácter pecuniario, el órgano competente para resolver el procedimiento aplicará reducciones de, al menos, el 20 % sobre el importe de la sanción propuesta, siendo éstos acumulables entre sí. Las citadas reducciones, deberán estar determinadas en la notificación de iniciación del procedimiento y su efectividad estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

El porcentaje de reducción previsto en este apartado podrá ser incrementado reglamentariamente.”

De acuerdo con lo señalado,
la Presidencia de la Agencia Española de Protección de Datos **RESUELVE**:

PRIMERO: DECLARAR la terminación del procedimiento **EXP202300329**, de conformidad con lo establecido en el artículo 85 de la LPACAP.

SEGUNDO: ORDENAR a **BANCO BILBAO VIZCAYA ARGENTARIA, S.A.**, con NIF **A48265169**, que en virtud del artículo 58.2.d) del RGPD, en el plazo de seis meses desde que la presente resolución sea firme y ejecutiva, acredite ante esta Agencia la adopción de las medidas necesarias para garantizar el cumplimiento de lo dispuesto en el artículo 32 del RGPD, a fin de evitar que se produzca un incidente similar al que dio origen al presente procedimiento.

TERCERO: NOTIFICAR la presente resolución a **BANCO BILBAO VIZCAYA ARGENTARIA, S.A.**

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa según lo preceptuado por el art. 114.1.c) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, los interesados podrán interponer recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-Administrativa, en el plazo de dos meses a contar desde el



día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

1398-101224

Olga Pérez Sanjuán

La Subdirectora General de Inspección de Datos, de conformidad con el art. 48.2 LOPDGDD, por vacancia del cargo de Presidencia y Adjuntía